# Spinlog: Ethics and Responsible – Use Statement

Team Members: Marcus Rowe and Owen Mueller

## 1. Privacy summary

| ID | Data item | Source | Purpose | Consent | Storage | Access | Retention |
|---|---|---|---|---|---|---|---|
| **P1** | Account identifiers: user_id, idp_subject, created_at | E2, C6 | Recognize a returning user without passwords (R2) | C-A | USERS | C6 writes; C3, C5 read user_id (I11, I13) | Until account deleted |
| **P2** | Refresh token: token_hash, expires_at, revoked_at | C6 | Stay signed in 30 days (R3) | C-A | REFRESH_TOKENS; phone secure storage | C6; the app reads its own copy | Expires in 30 days; revoked on use, sign-out, or reuse (EC-42); expired rows purged daily; deleted with account |
| **P3** | Session token | C6 | Authorize API calls (I7, I8) | C-A | Phone memory | C3, C5, C6 verify it | Expires in 15 minutes |
| **P4** | OAuth values: code, code_verifier, state, client_secret | E2, C6 | Complete PKCE sign-in | C-A | Memory; client_secret in server environment | Backend; hosting member | Not persisted; secret revoked at project end |
| **P5** | Identity-provider tokens: id_token, access_token, refresh_token | E2 | id_token read once for idp_subject; others unused | C-A | Not stored (no D1 column) | C6, during sign-in | Discarded after sign-in |
| **P6** | Reader pairing token | C6 | Prove which user owns a reader (R4) | C-C | DEVICES (hash); reader flash | C3, C6 (I10, I13) | Cleared on revoke, on 401 (EC-15), and by the 10-second reset; revoked rows purged after 30 days; deleted with account |
| **P7** | Reader record: device_id, last_seen_at, revoked_at | C6 | List readers and show online status (S6) | C-C | DEVICES | C6; own readers only | As P6 |
| **P8** | Wi-Fi name, password, server address | C1 | Let the reader reach the server | C-C | Reader flash | Reader; anyone holding it can read flash unless encrypted (D6) | 10-second reset; discarded if Bluetooth drops (D2 2.2.2) |
| **P9** | Tap: tag_uid, played_at, event_id | C2 | Identify the record and count each tap once | C-C | Reader flash queue | C2 | Removed on logged or duplicate; oldest dropped at 100 (EC-09); cleared on 401 |
| **P10** | Tag link: user_id, tag_uid, record_id | C5 | Map a tag to a record | C-C | TAGS | C3, C5, by user_id | Unlink deletes it; deleted with account |

| | | | | | | | |
|---|---|---|---|---|---|---|---|
| **P11** | Play history: user_id, record_id, device_id, played_at, event_id | C3 | Play counts and last played (US-03). Our most revealing data | C-C | PLAYS | C3 writes; C5 reads; own user_id only (EC-35) | Until account deleted; single plays deletable |
| **P12** | Record ownership: added_at, removed_at, condition, notes | C5 | Show collection; value over time | C-C | RECORDS | C5, by user_id | Remove keeps the row for value history and clears notes; deleted with account |
| **P13** | Hand-entered release: artist, title, genre, year, created_by_user_id | C5 | Catalogue albums missing from Discogs | C-C | RELEASES | C5; creator only | Deleted with account |
| **P14** | Discogs release data: discogs_release_id, artist, title, label, year, genres, cover_url | E3 | Show the user's records | C-C | RELEASES | C5; not personal alone | Kept while referenced, orphans deleted daily |
| **P15** | Barcode: camera frames, 8 to 14 digit string | C1 | Look up candidate releases | C-B | Phone memory | C1; C5 forwards the string to Discogs without user identity | Not stored |
| **P16** | Price snapshots: release_id, snapshot_date, lowest_price, num_for_sale | E3, C4 | Value chart (R7, R8) | no user data | PRICE_SNAPSHOTS | C4 writes; C5 reads | Dropped with the database at project end |
| **P17** | Value history and play counts (derived) | C5, C3 | Charts on S2, S3, S5 | As P11, P12 | Phone memory | Signed-in user | Gone when the screen closes |
| **P18** | Link session | C5 | Link a tag by tapping the reader (R1) | C-C | Undecided (D4) | C3, C5 | Expires in 2 minutes (EC-32) |
| **P19** | Console logs: sign-ins, 401 and 403 refusals, retries, unassigned taps | Backend | Debugging | C-A | Docker log on host | Host team members | 7-day rotation; no tokens, passwords, Wi-Fi details, or email; user_id only |
| **P20** | App settings (api_base_url) and screen caches | C1 | Reach the server; draw screens | C-C | Phone | The app | Until changed or uninstalled; caches clear with the screen |

**Consent:**

**C-A:** Sign-in screen S1, “Continue” is disabled until the user agrees. Shows the user what all is stored and asks for permission.

**C-B:** OS permission prompts: camera at S4, Bluetooth at S7.

**C-C:** Users actions: typing Wi-Fi password, pairing, linking, logging plays.

## 2. Security summary

**Default credentials:** Spinlog has no passwords of its own. User must sign in through an **identity provider** in the phone systems browser and C6 verifies the id_token signature against the providers published keys (I4, I9). There is no shared reader password, each reader gets its own pairing token from C6 when paired. No token or Wi-Fi detail is compiled because both arrive over Bluetooth in setup mode (I5). The PostgreSQL password is set through an environment variable.

**Unauthenticated endpoints:** Every call except three need a credential. The session token is signed, lasts **15 minutes**, and is not stored on the server. The refresh token lasts **30 days** and **is stored as a hash**. If a used token is used again after 10 seconds, all of that users' tokens are revoked. Readers send their pairing token on POST /api/v1/taps and GET /api/v1/devices/me. The three endpoints open by design are /auth/token, which nees a one time code and verifier, and /auth/refresh and /auth/logout which need a refresh token. Every database query is scoped by the user_id, and a request for another users' record or reader returns a 403.

Two mechanisms are not yet met, HTTPS and rate limiting. D2 specifies phone and reader traffic as plain HTTP on a private network, so pairing and session tokens travel in plain text in the demo. This product is only meant for a few known users at this point, so any launch after that would require security upgrades. Rate limiting is not specified for our own API yet, only the Discogs API. Again, if we upgrade to a more formal launch the rate limiting will also need an upgrade.

**Secrets in source control:** Server secrets (identity provider client secret, Discogs token, database password, and token signing key) live in environment variables read once at startup. .env will be in .gitignore so no secrets are published to the github. On the phone the refresh token are in OS secure storage. On the reader Wi -Fi details and the pairing tokens are in flash.

**Self-audit:**

| Question | Answer |
|---|---|
| **Are default credentials stored anywhere?** | No. We use an identity provider sign in. |
| **Can one user read or change another's data?** | No. Every query is scoped by user_id. |
| **Is traffic encrypted in transit?** | Database yes, everything else no (needs upgrade if launched) |
| **What happens if a token or reader is stolen?** | Session tokens expire in 15 minutes, refresh token reuse revokes everything |
| **Is there brute-force protection?** | No, also needs upgraded if launched |
| **Do logs hold sensitive data?** | No. |
| **Are dependencies checked for known vulnerabilities?** | Not yet, but this should be done once we write the code |

**Result of git history:** No committed secrets were found in our git history.

## 3. Licensing Summary:

| Name | Version | License | Permissive or copy/left | Obligation |
|---|---|---|---|---|
| **PostgreSQL** | 18.6 | PostgreSQL | Permissive | Keep the copyright notice in any distributed copy. |
| **Python** | 3.14.10 | Python-2.0 | Permissive | Keep the license notice when redistributing Python. |
| **Psycopg 3** | 3.3.8 | LGPL-3.0-only | Copyleft | We do not modify it. If we distribute it, include the LGPL-3.0 test, link to its source, and keep it replaceable. |
| **SQLAlchemy** | 2.1.1 | MIT | Permissive | Keep the copyright and license notice. |
| **FastAPI** | 0.162.2 | MIT | Permissive | Keep the copyright and license notice. |
| **Pydantic** | 2.14.3 | MIT | Permissive | Keep the copyright and license notice. |
| **Uvicorn** | 0.54.0 | BSD-3-Clause | Permissive | Keep the notice. Do not use contributors' names to endorse the project. |
| **React Native** | 0.88.0 | MIT | Permissive | Keep the copyright and license notice. |
| **NFC reader driver for the PN532 chip** | jef-sure/pn532 0.8.x | MIT | Permissive | Keep the copyright and license notice. |
| **ESP-IDF** | v6.0.3 | Apache-2.0 | Permissive | Keep the license and NOTICE files. Mark changed files. ESP-IDF includes third-party components under BSD, MIT, and Apache licenses. |
| **esptool.py** | 5.2.0 | GPL-2.0 | Copyleft | Not shipped in the firmware, so it places no obligation on our code |
| **Arduino core for ESP32** | Not used | LGPL-2.1 | Copyleft | Excluded. The firmware is built on ESP-IDF instead. |
| **Docker Engine** | 29.9.1 | Apache-2.0 | Permissive | If we publish an image, include the notices. |
| **Discogs metadata** | Discogs API v2.0 | CC0-1.0 per Discogs' data list | Permissive | Attribution and notices still apply under the Discogs terms |
| **Discogs release and artist images** | Discogs API v2.0 | Discogs API Terms of Use | Restricted | Display in the app only. Store the image URL, not a copy |
| **Discogs marketplace prices and listing counts** | Discogs API v2.0 | Discogs API Terms of Use | Restricted | No commercial use. |
| **Team-made assets: app icon, screens, this document** | Not applicable | MIT (team's own work) | Permissive | None yet. Any third-party font, icon set, or image must be added to this table with its license before use. |

**Compatibility check:**

- **MIT project and permissive dependencies:** Compatible. The only duties are keeping notices.
- **Psycopg:** Compatible when used unmodified as a library. The duties apply only when we distribute it.
- **Discogs data:** The MIT license grants nothing in Discogs data. Our use is under the Discogs terms above, which the MIT grant must not override.
- **Excluded or unshipped copyleft:** Kept out of the firmware.

**Decisions made in this section:**

- Project license: MIT for code and team-written documents.
- Firmware SDK: ESP-IDF. Arduino core excluded.
- psycopg 3 kept and used unmodified, with its LGPL notice and source link in the release.
- Discogs data: follow the twelve Discogs terms listed under Table A. Charge no fees and show no ads.
- Price snapshots kept while the account exists.

## 4. Attribution List

**Libraries and tools:**

| Library or tool | Version | Source URL | License | Used for |
|---|---|---|---|---|
| **PostgreSQL** | 18.6 | https://www.postgresql.org/ | PostgreSQL | Database |
| **Python** | 3.14.10 | https://www.python.org/ | Python-2.0 | Server runtime |
| **psycopg3** | 3.3.8 | https://github.com/psycopg/psycopg | LGPL-3.0-only | Database driver |
| **SQLAlchemy** | 2.2.1 | https://github.com/sqlalchemy/sqlalchemy | MIT | Database Access |
| **FastAPI** | 0.162.2 | https://github.com/fastapi/fastapi | MIT | API framework |
| **Pydantic** | 2.14.3 | https://github.com/pydantic/pydantic | MIT | Request validation |
| **Uvicorn** | 0.54.0 | https://github.com/Kludex/uvicorn | SD-3-Clause | Server |
| **React Native** | 0.88.0 | https://github.com/react/react-native | MIT | Phone app |
| **ESP-IDF** | V6.0.3 | https://github.com/espressif/esp-idf | Apache-2.0 | Reader firmware SDK |
| **Esptool.py** | 5.2.0 | https://github.com/espressif/esptool | GPL-2.0 | Flashing the reader from a developer machine |
| **Docker Engine** | 29.9.1 | https://github.com/moby/moby | Apache-2.0 | Local development, if used |
| **PN532 driver** | 0.8.x | https://components.espressif.com/components/jef-sure/pn532/versions/0.8.2/readme | MIT | NFC reader driver |

**Code adapted from other sources:** None yet. Any code copied or adapted from a tutorial or another repository must be added here with its source URL and license before it is committed.

**Datasets:**

| Dataset | Version | Source URL | Collection Method | Usage Restrictions |
|---|---|---|---|---|
| **Discogs release, artist, and label metadata** | Discogs API v2.0 | https://www.discogs.com/developers | Requested through the Discogs API when a user searches for a record or links one. Stored in RELEASES. | CC0 per Discogs' data list (verify). Attribution required: "Data provided by Discogs." Discogs terms 1 to 12 apply |
| **Discogs release and artist images** | Discogs API v2.0 | https://www.discogs.com/developers | Image URLs returned by the API. Only the URL is stored. | Restricted Data. Display in the app only. No copies stored. |
| **Discogs marketplace prices and listing counts** | Discogs API v2.0 | https://www.discogs.com/developers | Nightly job requesting owned releases once per day | Restricted Data. No commercial use. |

**Non code assets:**

None yet. The team has not added icons, fonts, images, or sound. Any such asset must be listed here with its author, source URL, and license before it is used.

**Required notices:**

The app must show "Data provided by Discogs." next to Discogs data, and the trademark notice "This application uses Discogs' API but is not affiliated with, sponsored or endorsed by Discogs. 'Discogs' is a trademark of Zink Media, LLC."

## 5. AI-use disclosure:

“Generative AI tools may be used for drafting and code assistance but not for the design decisions or written analysis that are assessed in this course”

| Tool | Used by | Task | Column | How verified |
|---|---|---|---|---|
| **Claude** | Marcus and Owen | Improving the layout of the D0, D1, and D2 design figures | Generally OK | The team read through every figure and checked that the content matched what the team created. |
| **Claude** | Marcus and Owen | Converting design documents and other project files to Markdown | Generally OK | The team read through every figure and checked that the content matched what the team created. |
| **Claude** | Marcus and Owen | Researching licensing and terms. | Generally OK | Claude read the terms from search results. The team double checked the licenses and terms to ensure accuracy. |
| **Claude** | Marcus and Owen | Coherency checking throughout assignments | Generally OK | The team read through every problem that arose and verified it by hand. |

Each member signs below to confirm that the architecture, data model, priorities, and design rationale in this project are the team's own work.

Marcus Rowe: *Marcus Rowe* Date: 11/12/2026

Owen Mueller: *Owen Mueller* Date: 11/12/2026